

Отчет по пятому этапу индивидуального проекта

Основы информационной безопасности

Содержание

1	Цель работы	5
2	Теоретическое введение	6
3	Выполнение лабораторной работы	7
4	Выводы	9

Список иллюстраций

Список таблиц

1 Цель работы

Научиться использовать Burp Suite.

2 Теоретическое введение

Burp Suite представляет собой набор мощных инструментов безопасности веб-приложений, которые демонстрируют реальные возможности злоумышленника, проникающего в веб-приложения. Эти инструменты позволяют сканировать, анализировать и использовать веб-приложения с помощью ручных и автоматических методов. Интеграция интерфейсов этих инструментов обеспечивает полную платформу атаки для обмена информацией между одним или несколькими инструментами, что делает Burp Suite очень эффективной и простой в использовании платформой для атаки веб-приложений.

3 Выполнение лабораторной работы

Запускаю локальный сервер, на котором открою веб-приложение DVWA для тестирования инструмента Burp Suite (рис.

Запускаю инструмент Burp Suite (рис.).

Открываю сетевые настройки браузера, для подготовке к работе (рис.).

Изменение настроек сервера для работы с проху и захватом данных с помощью Burp Suite (рис.).

Изменяю настройки Проху инструмента Burp Suite для дальнейшей работы (рис.).

Во вкладке Проху устанавливаю “Intercept is on” (рис.).

Чтобы Burp Suite исправно работал с локальным сервером, необходимо установить параметр `network_allow_hijacking_localhost` на `true`

Пытаюсь зайти в браузере на DVWA, тут же во вкладки Проху появляется захваченный запрос. Нажимаем “Forward”, чтобы загрузить страницу (рис.).

Загрузилась страница авторизации, текст запроса поменялся (рис.).

История запросов хранится во вкладке Target (рис.).

Попробуем ввести неправильные, случайные данные в веб-приложении и нажмем Login. В запросе увидим строку, в которой отображаются введенные нами данные, то есть поле для ввода (рис.).

Этот запрос так же можно найти во вкладке Target, там же жмем правой кнопкой мыши на хост нужного запроса, и далее нажимаем “Send to Intruder” (рис.).

Попадаем на вкладку Intruder, видим значения по умолчанию у типа атаки и

наш запрос (рис.).

Изменяем значение типа атаки на Cluster bomb и проставляем специальные символы у тех данных в форме для ввода, которые будем пробивать, то есть у имени пользователя и пароля (рис.).

Так как мы отметили два параметра для подбора, то нам нужно два списка со значениями для подбора. Заполняем первый список в Payload setting (рис.).

Переключаемся на второй список и добавляем значения в него. В строке request count видим нужное количество запросов, чтобы проверить все возможные пары пользователь-пароль (рис.).

Запускаю атаку и начинаю подбор (рис.).

При открытии результата каждого post-запроса можно увидеть полученный get-запрос, в нем видно, куда нас перенаправило после выполнения ввода пары пользователь-пароль. В представленном случае с подбором пары admin-admin нас перенаправило на login.php, это значит, что пара не подходит (рис.).

Проверим результат пары admin-password во вкладке Response, теперь нас перенаправляет на страницу index.php, значит пара должна быть верной (рис.).

Дополнительная проверка с использованием Repeater, нажимаем на нужный нам запрос правой кнопкой мыши и жмем “Send to Repeater” (рис.).

Переходим во вкладку “Repeater” (рис.).

Нажимаем “send”, получаем в Response в результат перенаправление на index.php (рис.).

После нажатия на Follow redirection, получим неcompiled html код в окне Response (рис.).

Далее в подокне Render получим то, как выглядит полученная страница (рис.).

4 Выводы

При выполнении лабораторной работы научилась использовать инструмент Burp Suite.